



МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

ЛЕКЦИОННЫЕ МАТЕРИАЛЫ

Системы мониторинга и управления инцидентами информационной безопасности

	<i>(наименование дисциплины (модуля) в соответствии с учебным планом)</i>
Уровень	
	<i>(бакалавриат, магистратура, специалитет)</i>
Форма обучения	
	<i>(очная, очно-заочная, заочная)</i>
Направление(-я) подготовки	
	<i>(код(-ы) и наименование(-я))</i>
Институт	Институт кибербезопасности и цифровых технологий
	<i>(полное и краткое наименование)</i>
Кафедра	Интеллектуальные системы информационной безопасности
	<i>(полное и краткое наименование кафедры, реализующей дисциплину (модуль))</i>
Лектор	к.т.н., Урасков Юрий Леонидович
	<i>(сокращенно – ученая степень, ученое звание; полностью – ФИО)</i>
Используются в данной редакции с учебного года	2022/23
	<i>(учебный год цифрами)</i>
Проверено и согласовано «___» _____ 20__ г.	
	<i>(подпись директора Института/Филиала с расшифровкой)</i>

Москва 2022 г.

Лекция 5. Анализ XDR-систем.

Подходы киберпреступников с каждым годом становятся всё более изощрёнными и быстро адаптируемыми к новым реалиям. Наглядным тому примером служит успешное использование такого мирового события, как пандемия COVID-19. Злоумышленники всё чаще практикуют мультивекторный подход к организации своих атак, используют несколько точек проникновения в инфраструктуры жертв, социальную инженерию, а также применяют горизонтальное перемещение по сети. Всё это приводит к расширению площади атаки и усложняет процесс реагирования на инциденты связанные с киберугрозами, целенаправленными и APT-атаками.

Для устранения такого рода нападений использование только базовой превентивной защиты или передового защитного инструмента, который ориентирован на один вектор атаки, становится недостаточным. Средние и крупные организации, осознавая факторы риска для бизнеса, поступательно наращивают свой ИБ-арсенал. Они зачастую становятся обладателями большого количества неинтегрированных между собой ИБ-инструментов, в том числе по обнаружению, расследованию и реагированию, и ряда консолей управления (примеры инструментов: EDR, NTA, NGFW, Mail Gateway, Sandbox, TIP, CASB, IRP).

Все эти решения направлены на противостояние киберугрозам, но одни из них закрывают только отдельные векторы атаки (сеть, почта, облака и пр.), а другие отвечают за какие-то определённые действия в рамках процесса реагирования на инциденты (обнаружение, обогащение событий, реагирование и пр.). Усилия по эксплуатации такого «зоопарка» решений имеют разную степень успеха, но чаще всего организации страдают от чрезвычайно высокого потребления ресурсов и преобладания несистематического подхода к обработке инцидентов. Даже те организации, которые давно уже используют решения класса SIEM, в большинстве случаев завалены большим количеством оповещений, требующих интенсивного и

экстенсивного вовлечения ИБ-специалистов и большого количества ручных действий по расследованию и анализу.

Для решения этого набора проблем был создан новый класс решений XDR (Extended Detection and Response), который, по мнению Gartner, входит в тройку лучших проектов в области кибербезопасности в 2022 году.

Определение XDR

XDR (от англ. **Extended Detection and Response**, «расширенное обнаружение и реагирование») – класс систем информационной безопасности, предназначенных для автоматического проактивного выявления угроз на разных уровнях инфраструктуры, реагирования на них и противодействия сложным атакам. Это следующий шаг в развитии технологии **EDR** (Endpoint Detection and Response), которая отвечает за обнаружение сложных угроз и реагирование на них на уровне конечных точек. EDR не охватывает защиту других частей инфраструктуры, не связанных с рабочими местами, таких как сеть, почта, учётные записи, облачные среды и пр. XDR объединяет EDR с другими инструментами безопасности либо источниками данных, консолидированно собирает и сопоставляет эти данные и предоставляет аналитикам расширенные возможности по обнаружению, расследованию и реагированию на сложные киберугрозы.

XDR включает широкий набор инструментов, которые интегрируются с имеющимися программами и приложениями для обеспечения безопасности и обеспечивают мониторинг данных на уровне конечных точек, сети, облака и серверов электронной почты, а также функции аналитики и автоматизации для обнаружения и устранения текущих и потенциальных угроз.

Например, XDR может объединять EDR с такими продуктами, как межсетевые экраны, системы сетевого анализа, решения по защите облаков, веб-шлюзы и шлюзы электронной почты, инструменты по управлению правами доступа и прочие классы решений в рамках единого процесса реагирования на инциденты. Получается, что XDR объединяет различные

ИБ-решения в единую эффективную систему безопасности. Важно, что интеграция происходит на этапе развёртывания, а не добавляется позже, как, например, при подключении SIEM- или SOAR-систем.

Решение XDR подходит для средних и крупных компаний, которые стремятся упростить управление своей инфраструктурой информационной безопасности преимущественно в рамках продуктов от одного вендора. Это позволяет прагматичным организациям значительно повысить операционную эффективность своей ИБ-системы без ручной и трудозатратной интеграции, при этом максимально автоматизировав и упростив процесс реагирования на инциденты, а также оптимизировав ИБ-ресурсы.

Ценность XDR определяется удобством эксплуатации, повышением уровня автоматизации и эффективности процесса поиска угроз и реагирования на них. Это происходит за счёт предоставления информации в консолидированном виде из единой консоли, применения механизмов искусственного интеллекта для повышения скорости обнаружения и приоритизации инцидентов и встроенного анализа угроз. Также свою роль в этом играют предоставление экспертам большей видимости и лучшего понимания угроз, объединение оповещений в инциденты, возможность более глубокого анализа первопричин и централизованное реагирование в рамках всей инфраструктуры.

Состав и функциональные возможности XDR

Процесс работы с киберинцидентами, связанными со сложными угрозами и целевыми атаками, предполагает наличие выстроенного процесса реагирования, а точнее — выполнение быстрых и точных действий по сбору данных, обнаружению, расследованию и нейтрализации угроз. Важно исключить вероятность упустить оповещения из общего потока, которые могут привести к негативным последствиям.

Сегодня обработке всего объёма подозрительных предупреждений мешает следующее:

- большое количество ложноположительных срабатываний,
- нехватка аналитиков и их усталость от большого потока оповещений,
- недостаток необходимых знаний у аналитиков,
- большое количество ручных задач, связанных с валидацией, приоритизацией, сопоставлением оповещений в единый инцидент, реагированием на инциденты и пр.

Аналитическая компания Enterprise Strategy Group в своём исследовании «Влияние XDR на современный SOC» выделила следующие ключевые факторы успеха, способствующие повышению эффективности процесса обнаружения и реагирования (рисунок 1):

- улучшение обнаружения сложных угроз,
- повышение автоматизации и улучшение показателей среднего времени обнаружения и реагирования на угрозы (MTTD / MTTR),
- улучшение видимости того, что происходит в инфраструктуре, и понимание угроз,
- уменьшение количества ложных срабатываний и улучшение приоритизации инцидентов,
- увеличение ежедневного объёма обработанных инцидентов,
- предоставление аналитикам возможностей по проактивному поиску угроз.

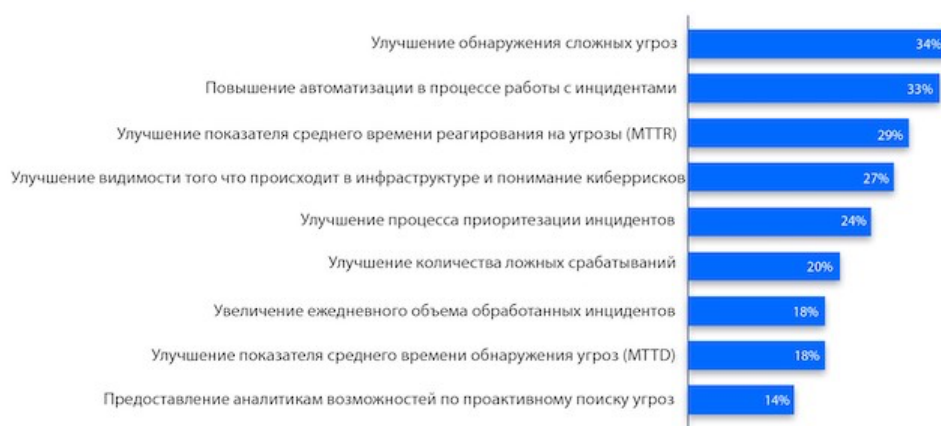


Рисунок 1. Необходимые улучшения для повышения эффективности процесса обнаружения угроз и реагирования на них

С помощью XDR аналитики ИБ получают единую мощную платформу для расширенного обнаружения, расследования и реагирования на сложные киберинциденты при меньших трудозатратах.

Это возможно благодаря:

- единому центру сбора, нормализации, анализа и корреляции данных,
- облачному «озеру данных» (data lake) или локальной базе данных (менее распространено),
- единой консоли,
- повышенному уровню автоматизации,
- единой точке видимости того, что происходит в инфраструктуре,
- единому инструментарию по анализу первопричин и проактивному поиску угроз,
- единому улучшенному процессу приоритизации инцидентов,
- автоматическому формированию из ряда оповещений одного инцидента, который действительно требует внимания аналитиков,
- одной точке взаимодействия с Threat Intelligence и матрицей MITRE ATT&CK,
- централизованному реагированию, в том числе с применением сценариев реагирования (плейбуков) и пр.

Количество подключаемых в единую среду взаимодействия источников(продуктов), которые участвуют в процессе обнаружения, расследования и реагирования, зависит от потребностей заказчика, а также от выбранного поставщика XDR, то есть от его собственных поддерживаемых источников (классов продуктов) и возможностей интеграции со сторонними ИБ-решениями. EDR и различные защитные средства, такие как почтовые и веб-шлюзы, межсетевые экраны, IPS, NTA / NTDR, CASB, DLP, IDM, решения по защите банкоматов, АСУ ТП, IoT и ряд других, могут выступать сенсорами для XDR (рисунок 2).

Концепция Extended Detection and Response (XDR)

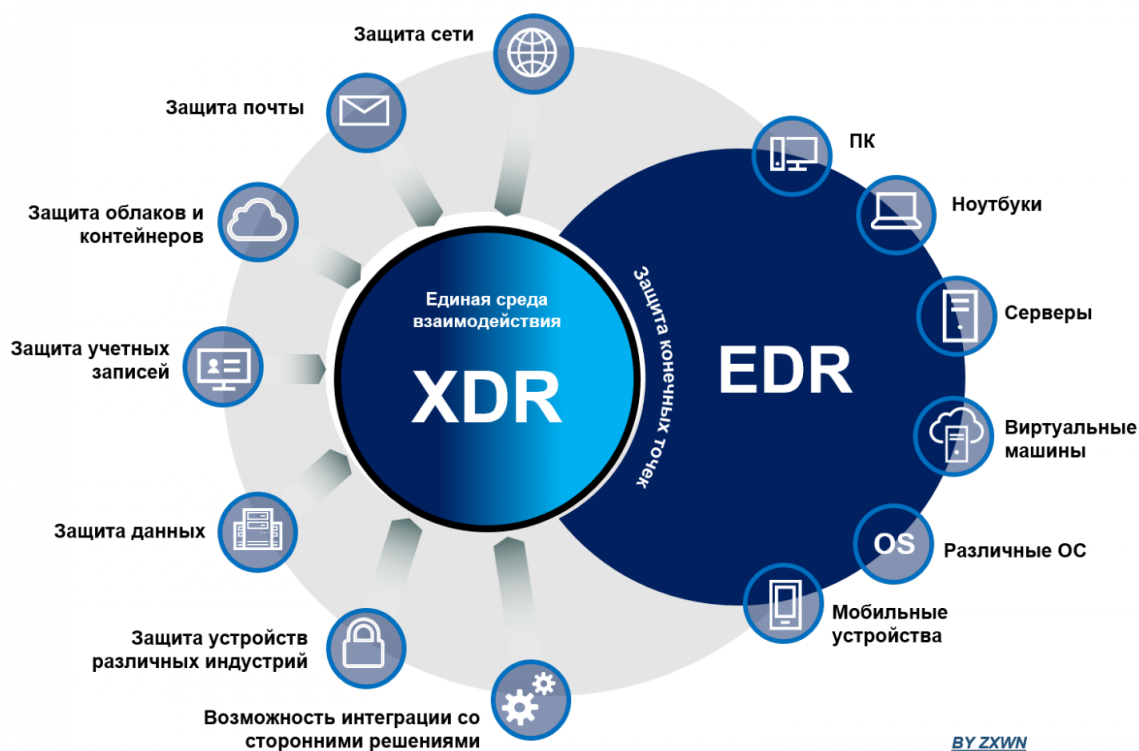


Рисунок 2. Пример состава решения класса XDR

Минимальный комплект XDR — это защита конечных точек, сети и почты, то есть объединение защиты наиболее популярных и эксплуатируемых злоумышленниками мест проникновения в инфраструктуру, которые следует контролировать в первую очередь. Также важно в базовой конфигурации обогащать полученные оповещения актуальными данными об угрозах (Threat Intelligence) и сопоставлять их с матрицей тактик и техник злоумышленников MITRE ATT&CK, что значительно упрощает и ускоряет процесс расследования.

По данным того же опроса Enterprise Strategy Group «Влияние XDR на современный SOC», самыми привлекательными возможностями XDR для организаций сегодня являются:

- упрощённая визуализация сложных атак и понимание всех её этапов и первопричин,
- расширенная аналитика и автоматизация в процессе реагирования,

- агрегация и корреляция данных из нескольких источников и средств управления безопасностью,
- улучшение показателей MTTD и MTTR и приоритизации инцидентов,
- консолидация нескольких инструментов безопасности в единое решение и пр.

Типы XDR и варианты поставки

В основе XDR обычно лежат продукты от одного вендора, но XDR не исключает возможности интеграции с решениями сторонних производителей. Уже сейчас аналитики, например Forrester, выделяют два типа XDR: нативный и гибридный (рисунок 3).

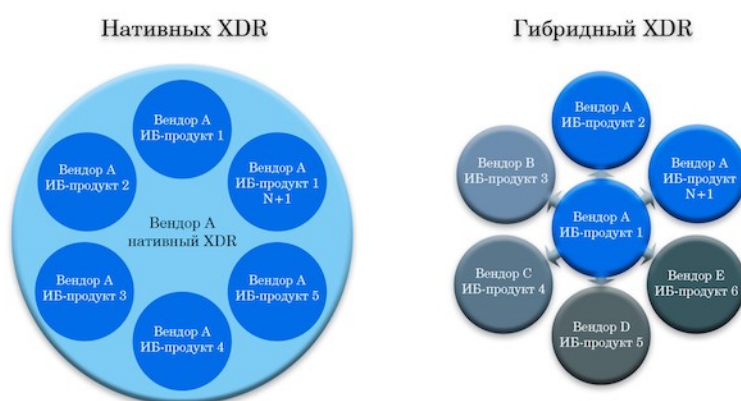


Рисунок 3. Типы XDR

Нативный XDR тесно связан с различными инструментами информационной безопасности в рамках портфолио от одного поставщика, тогда как гибридный XDR полагается в том числе на дополнительные ИБ-инструменты от других поставщиков.

Производители EDR с богатым набором иных ИБ-инструментов, конечно же, будут использовать тренд XDR как возможность максимально быстро унифицировать свой продуктовый портфель и предоставить более полное взаимодействие между своими ИБ-решениями, особенно если это

ранее ещё не было сделано. И, конечно, нативный XDR имеет преимущество потенциально простого лицензирования и тесной интеграции «из коробки» при поставке, но может не подойти организациям опасющимся привязки к одному производителю.

Напротив, вендоры с портфелем ограниченным одним или несколькими продуктами будут полагаться на дополнительные защитные инструменты от других поставщиков, что позволит службам безопасности подключать инструменты, которые они хотят интегрировать. Но, с другой стороны, взаимодействие с третьими сторонами не исключит вероятность поверхностных интеграций, что может отрицательно сказаться на эффективности решения XDR.

Отличия XDR от других систем информационной безопасности

Некоторые инструменты киберзащиты схожи с XDR, но из-за более узкой специализации в них, как правило, меньше функций. Например:

- **EDR** обеспечивают защиту только на уровне конечных точек, без сетевых и облачных служб.
- **SIEM** осуществляют только сбор и анализ информации во внутренней сети, без реагирования.
- **UEBA** анализируют только поведение пользователей, устройств и приложений, без реагирования на аномалии.
- **SOAR** охватывают большую часть инфраструктуры, но работают в основном по сигнатурам и типовым сценариям реагирования, не обеспечивая проактивную защиту. Кроме того, у решений типа SOAR более низкий уровень совместимости с решениями и приложениями, служащими источниками данных.

Недостатки XDR-решений

Технологии XDR относительно новы и очень перспективны, однако их использование сопряжено с определенными сложностями и рисками:

- На данный момент разные XDR-системы обладают очень разным набором возможностей, что усложняет их сравнение и выбор.
- Системы класса XDR включают в себя много различных функций, при этом вендоры, поставляющие эти системы, чаще всего специализируются в одном или нескольких направлениях, не охватывая все, что может привести к попыткам реализовать те или иные возможности без необходимой экспертизы. А это, в свою очередь, повышает вероятность ошибок.
- Некоторые XDR-системы совместимы только с защитными решениями определенного вендора или ограниченного числа вендоров. В связи с этим возможны ситуации, когда пользователям XDR придется искать компромисс между оптимальными для них узкоспециализированными решениями и полнотой использования XDR.

Наиболее известные решения класса XDR

Сегодня почти все EDR-вендоры, а это в сумме более 15 производителей по всему миру, заявили о своём переходе к XDR. Кто-то уже предлагает полноценные комплексы, а кто-то продолжает активно наращивать XDR-функциональность и взаимодействие между источниками данных. На сегодняшний день на мировом рынке широко представлены следующие решения класса XDR:

- Palo Alto Networks Cortex XDR,
- Fortinet FortiXDR,
- Kaspersky Anti Targeted Attack,
- Microsoft Defender,
- McAfee MVISION XDR,
- SentinelOne Singularity,
- Trend Micro Vision One.

Выводы

Решения класса XDR относительно новы и перспективны, так как призваны помочь компаниям с существующими ИБ-проблемами. XDR выводит работу ИБ-команд на новый уровень. ИБ-эксперты получают только требующие их внимания информативные оповещения, приоритизированные в зависимости от критической важности. Это становится возможным благодаря анализу данных, собранных со всей инфраструктуры, применению машинного обучения, встроенной Threat Intelligence и обогащению данными из матрицы MITRE ATT&CK. Большое количество ручных задач в рамках работы с инцидентами уходит в прошлое, что сокращает время на обнаружение, сдерживание угроз и их нейтрализацию. Богатый контекст по большему количеству векторов атаки даёт всеобъемлющее понимание первопричин, ускоряя процесс работы с инцидентами. В результате организации могут эффективно и оперативно отражать направленные на них кибератаки.